Penetration Test Report

Target: TryHackMe – “Cyborg” Room

Prepared by: Manoj Bora

Date: 24 September 2026

Classification: For Academic / Training Use Only

Document Control

Report Title	Penetration Test Report – TryHackMe Cyborg
Target	10.49.172.205 (TryHackMe lab instance)
Tester	Manoj Bora
Engagement Type	Black-box, authorized training lab (TryHackMe)
Date of Testing	21–22 September 2026
Date of Report	24 September 2026
Classification	For Academic / Training Use Only

Summary

This is a step-by-step report of the TryHackMe “Cyborg” room, done as practice for my Advanced Diploma in Cyber Security. It was a black-box test – I was given only the target IP and had to find everything else myself.

I scanned the box and found 2 open ports (SSH and HTTP). The web server had a hidden admin panel that leaked a Squid proxy password file, which contained a crackable hash. That password unlocked a backup archive protected with BorgBackup, and inside that backup was another user's password stored in plain text. That second user had sudo rights over a backup script, which I abused to get a root shell.

Flags captured:

- User flag: flag{1_hop3_y0u_ke3p_th3_arch1v3s_saf3}
- Root flag: flag{Than5s_f0r_play1ng_H0p£_y0u_enJ053d}

1. Reconnaissance – Port Scan

First step, like always, was a port scan to see what's open on the box.

```
sudo su
nmap -sS 10.49.172.205
```

The scan came back with 2 ports open:

- 22/tcp – SSH
- 80/tcp – HTTP



Figure 1 – Nmap SYN scan showing SSH (22) and HTTP (80) open

2. Web Enumeration – Finding the Admin Panel

Since port 80 was open, I checked the website in the browser and also ran directory brute-forcing (gobuster) on it to find hidden pages.

- This led me to an /admin/ page – an "Admin Shoutbox" page with messages between the admin users.
- One message from a user called Alex mentioned he had been messing around with a Squid proxy and left the config files lying around, and also mentioned a backup called "music_archive".

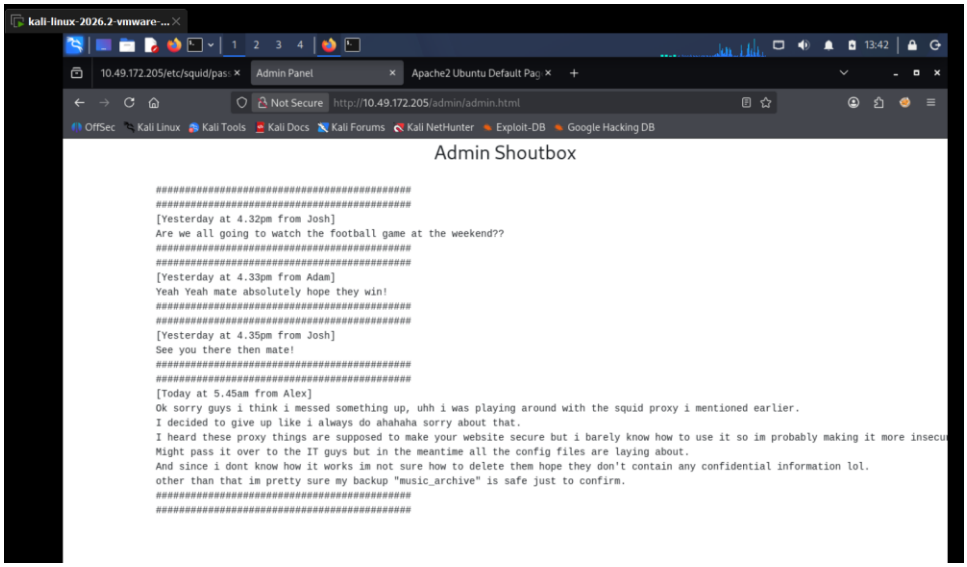


Figure 2 – Admin Shoutbox page, Alex's message about the Squid proxy and the music_archive backup

Following that lead, I browsed to the Squid config path mentioned and found a passwd file sitting there in the open.

```
http://10.49.172.205/etc/squid/passwd
```

- This file contained a username (music_archive) with an MD5-crypt style password hash next to it.

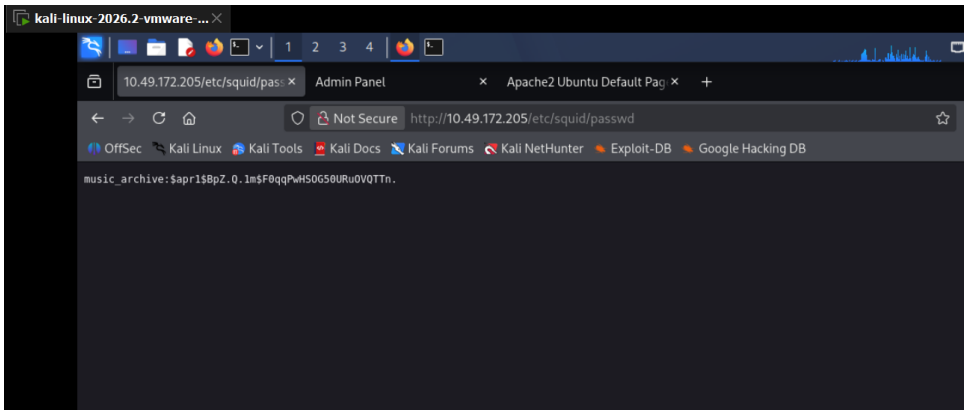


Figure 3 – Squid passwd file exposed on the web server, containing a crackable hash

3. Cracking the Hash

I saved the hash into a file and cracked it offline using John the Ripper with the rockyou wordlist.

```
nano hash.cyborg1
john hash.cyborg1 --wordlist=/usr/share/wordlists/rockyou.txt
```

John cracked it almost instantly:

- Username: music_archive
- Password: squidward

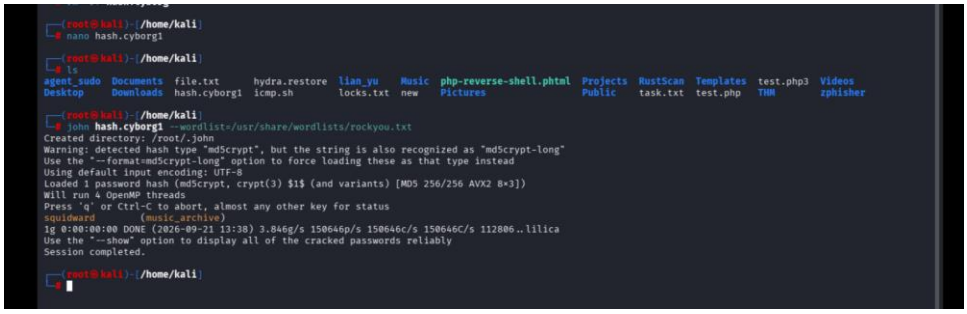


Figure 4 – John the Ripper cracking the Squid hash, result: squidward

4. Downloading and Extracting the Backup

With the cracked password in hand, I went back to the admin panel's Archive section and downloaded the backup file the shoutbox message had mentioned (“music_archive”).

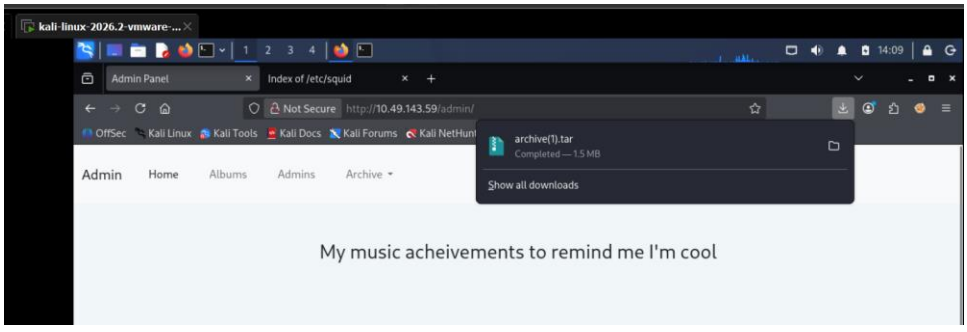


Figure 5 – Downloading archive(1).tar from the Admin Panel's Archive section

I extracted the tar archive and found a folder structure leading to a BorgBackup repository.

```
tar -xvf archive.tar
```

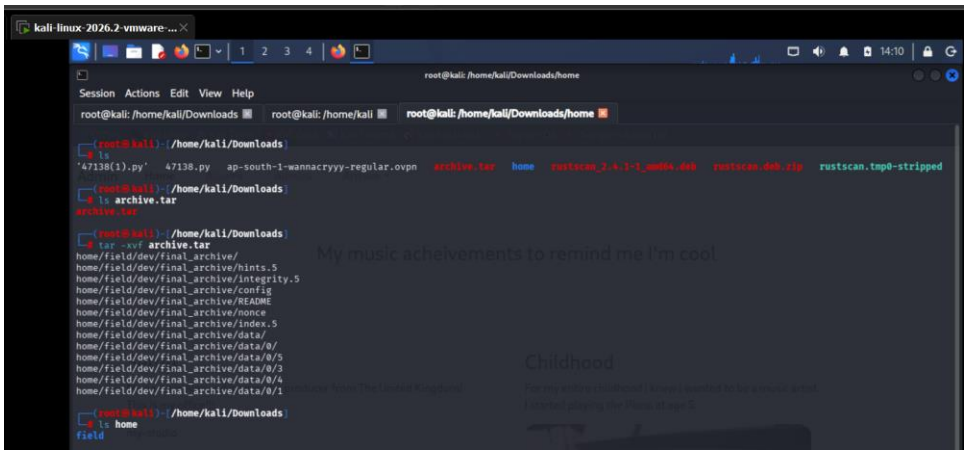


Figure 6 – Extracting archive.tar, revealing home/field/dev/final_archive/

Looking through the extracted folders with tree confirmed it was a full Borg repository (config, data, hints, index, integrity, nonce files).

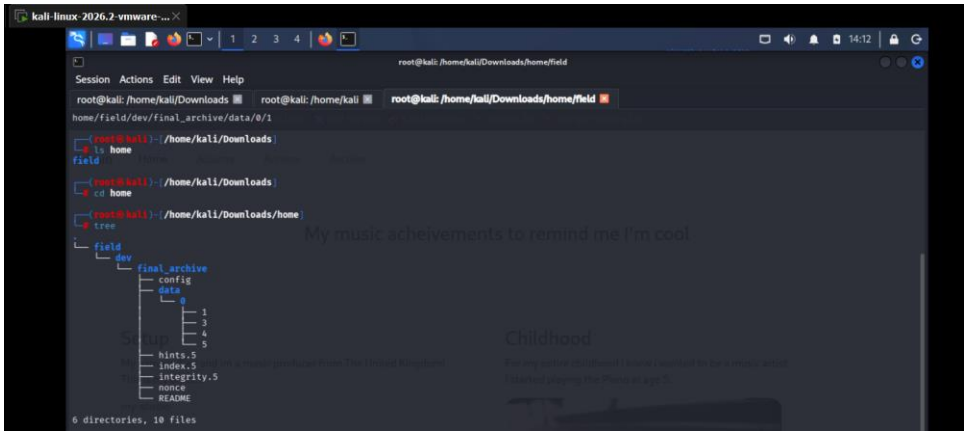


Figure 7 – Folder structure of the extracted final_archive (a Borg backup repo)

Checking the README inside confirmed this was in fact a BorgBackup repository, and the config file contained the repo's encryption key.

```
cat config
cat README
```

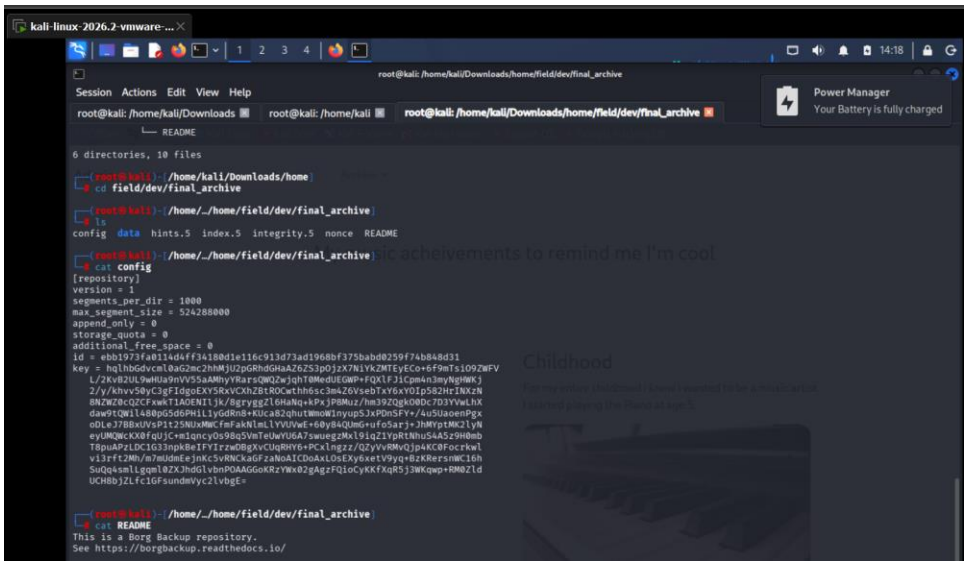


Figure 8 – config and README files confirming this is a BorgBackup repository

5. Unlocking the Borg Backup – Finding a Second User

BorgBackup archives are usually passphrase-protected. Since the Squid passwd hash had cracked to “squidward” and the archive itself was called “music_archive”, I tried that same password as the Borg passphrase – and it worked.

```
borg extract home/field/dev/final_archive::music_archive
```

Once extracted, I found a second home folder for another user called alex, with the usual folders. Inside Desktop and Documents there were two interesting files: secret.txt and note.txt.

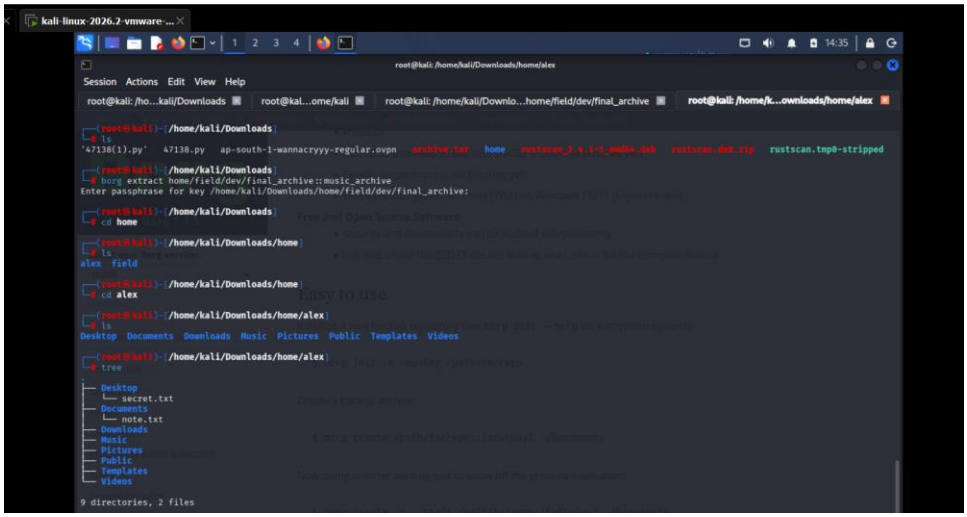


Figure 9 – Borg archive extracted, revealing a second user ‘alex’ with a full home directory

The note.txt file was the jackpot – alex had written his own SSH/login password down because he kept forgetting it.

```
cat secret.txt
cat note.txt
```

- Username: alex
- Password: S3cretP@s3



Figure 10 – secret.txt and note.txt, note.txt reveals alex's password (S3cretP@s3)

6. User Flag – SSH Access as Alex

With the credentials for alex, I logged in over SSH and grabbed the user flag right away.

```
ssh alex@10.49.172.205
cat user.txt
```

User flag: flag{1_hop3_y0u_ke3p_th3_arch1v3s_saf3}

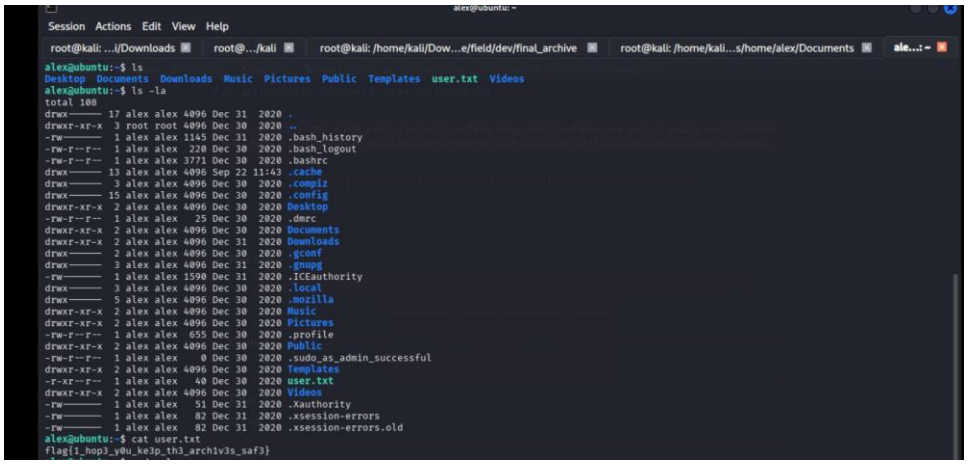


Figure 11 – Logged in as alex over SSH, user.txt flag captured

7. Privilege Escalation – Abusing a Sudo Backup Script

Next step was checking what alex could run with sudo.

```
sudo -l
```

This showed alex could run one script as root with no password needed:

```
(ALL : ALL) NOPASSWD: /etc/mp3backups/backup.sh
```

I ran the script as-is first to see what it did – it was backing up mp3 files from alex's Music folder into a tar archive.

```
sudo /etc/mp3backups/backup.sh
```

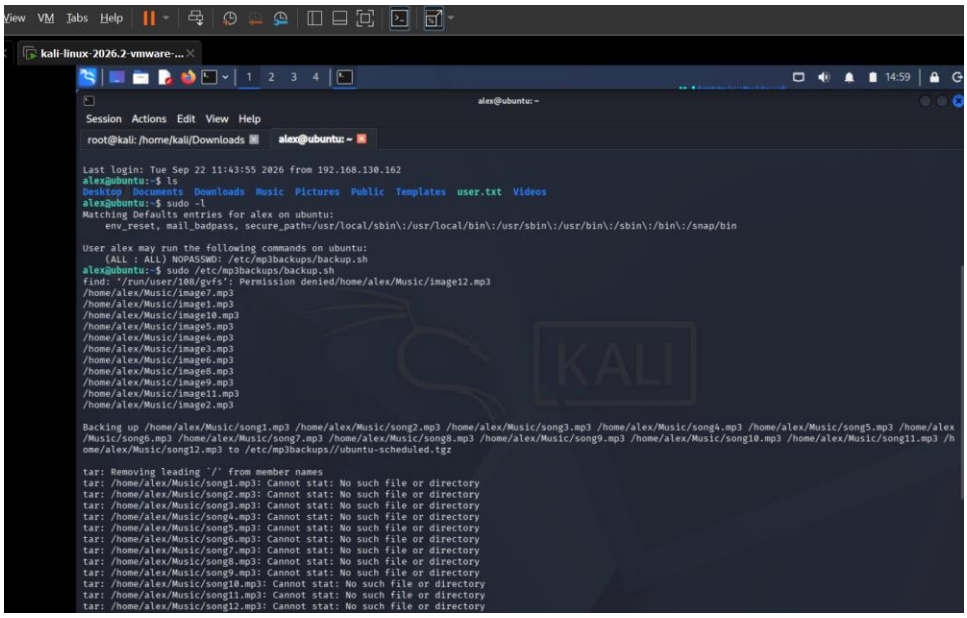


Figure 12 – sudo -l shows alex can run /etc/mp3backups/backup.sh as root with NOPASSWD

Since the script itself was owned by alex (writable), I could simply overwrite its contents. I made it writable, then replaced it with a command that spawns a privileged bash shell.

```
chmod 770 /etc/mp3backups/backup.sh
```



Figure 13 – Making the backup script writable with chmod 770

```
echo "/bin/bash -p" > /etc/mp3backups/backup.sh
sudo /etc/mp3backups/backup.sh
```

This dropped me straight into a root shell.

```
whoami
cd /root
cat root.txt
```

Root flag: flag{Than5s_f0r_play1ng_H0p£_y0u_enJ053d}

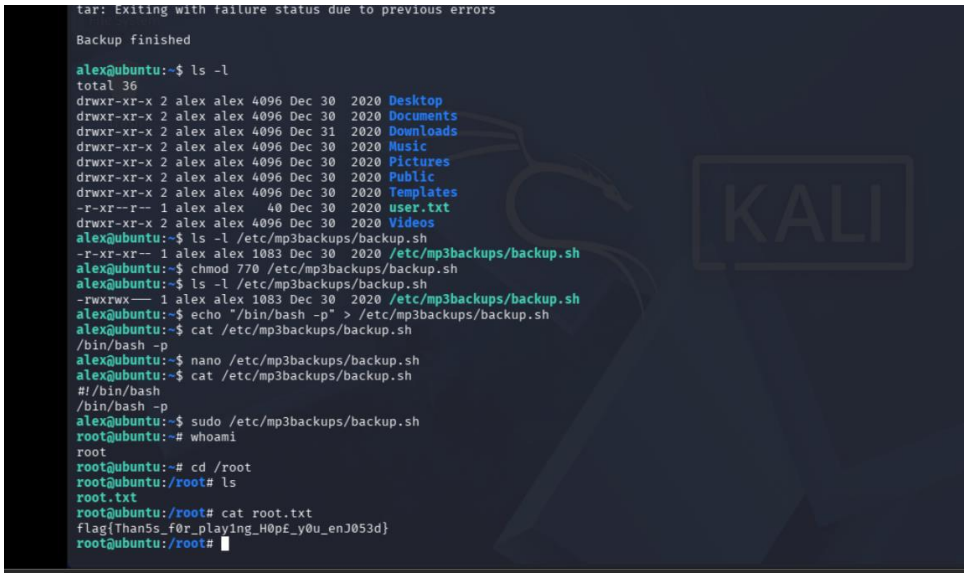


Figure 14 – Replacing the backup script with a shell payload, running it with sudo, and getting a root shell with root.txt

8. Summary of the Attack Chain

- Nmap scan found only SSH and HTTP open.
- Gobuster/manual browsing on the web server found a hidden /admin/ shoutbox page.
- The shoutbox leaked a path to an exposed Squid passwd file containing a crackable hash.
- John the Ripper cracked the hash to reveal the password “squidward”.
- That password doubled as the passphrase for a downloadable BorgBackup archive.
- Inside the Borg backup was a second user's (alex) home directory, with his password written down in a note.
- Alex's credentials gave SSH access and the user flag.
- Alex had NOPASSWD sudo rights over a writable backup script – overwriting it with a shell command gave a root shell and the root flag.

9. Learnings

- Never leave proxy or service config/password files reachable from the web root – even “hidden” paths get found by directory brute-forcing.
- Re-using the same password across different services/backups (Squid → Borg passphrase) lets one cracked credential unlock much more than intended.
- Never write plaintext passwords into notes/files on a system, even “temporarily.”
- Scripts called via sudo NOPASSWD must not be writable by the user who is allowed to run them – that combination is an instant root.